Rapport d'analyse technique de Petya, NotPetya et HybridPetya

UE SEC102 CNAM Nouvelle Aquitaine

L'évolution du chiffrement au niveau du démarrage (Boot Sector)

1. Introduction : La Mutation des Ransomwares de Bas Niveau

L'évolution de la famille Petya marque une rupture doctrinale dans l'ingénierie des menaces persistantes. En déplaçant le vecteur d'attaque du système de fichiers conventionnel vers le "socle de confiance" (Root of Trust) du matériel — spécifiquement le Master Boot Record (MBR) et l'Unified Extensible Firmware Interface (UEFI) — les attaquants neutralisent les piles de sécurité de l'OS avant leur initialisation. Cette approche garantit une persistance pré-boot et une inhibition totale des capacités de réponse aux incidents traditionnelles.

Implications Stratégiques

La compromission de la Master File Table (MFT) redéfinit la létalité du ransomware. Plutôt que de s'engager dans un chiffrement chronophage de fichiers individuels, l'attaquant s'attaque aux métadonnées NTFS. En l'absence de MFT fonctionnelle, l'OS est incapable de localiser les blocs de données, rendant le volume structurellement illisible. Cette transition technique a transformé le ransomware, initialement outil d'extorsion, en une arme de sabotage systémique capable de paralyser des infrastructures critiques à l'échelle mondiale.

---

2. Petya et NotPetya : Les Fondations de l'Attaque par le MBR

Apparu en 2016, le Petya original ciblait le MBR pour forcer le chiffrement de la MFT via l'algorithme Salsa20. Cependant, sa variante **NotPetya (2017)** a introduit une sophistication nettement supérieure, hybridant capacités de propagation réseau et impuissance cryptographique volontaire.

Analyse de la sophistication et vecteur de destruction

- **Propagation Latérale et Exploitation :** NotPetya a capitalisé sur l'exploit **EternalBlue (CVE-2017-0144)** ciblant le protocole SMBv1. Contrairement aux ransomwares opportunistes, NotPetya extrayait les secrets d'authentification directement depuis la mémoire de lsass.exe via un module dérivé de Mimikatz, utilisant ensuite l'impersonnalisation de jetons (Token Impersonation) pour infecter les nœuds adjacents sans interaction humaine.
- **Impuissance Cryptographique (Wiper) :** Bien qu'il simule une demande de rançon, NotPetya est techniquement un **wiper**. L'analyse forensique révèle que l'identifiant d'installation affiché à l'utilisateur est généré de manière arbitraire par une fonction de type CryptGenRandom. De plus, l'utilisation d'un portefeuille Bitcoin unique et fixe pour toutes les infections rend le suivi des paiements impossible pour l'attaquant. Il n'existe aucun lien cryptographique entre la clé

de session et l'identifiant affiché, rendant la restauration des données techniquement irréalisable.

Privilèges critiques et impact sur l'exécution

L'exécution optimale de la charge utile nécessite l'acquisition de privilèges spécifiques, dictant la profondeur de la compromission :

- **SeShutdownPrivilege :** Indispensable pour forcer le redémarrage système via NtRaiseHardError et transférer le contrôle au bootloader malveillant.
- **SeDebugPrivilege :** Requis pour l'injection de code et l'accès à la mémoire de processus tiers, notamment pour le siphonnage de lsass.exe.
- **SeTcbPrivilege :** Permet au processus de "Trusted Computer Base" d'assumer l'identité de n'importe quel utilisateur, facilitant la progression latérale via des jetons dupliqués.

---

3. HybridPetya : Infiltration des Environnements UEFI et Bypass du Secure Boot

Découvert en **février 2025** suite à l'analyse d'échantillons téléchargés depuis la **Pologne** sur VirusTotal, **HybridPetya** représente l'état de l'art de la compromission de bas niveau. Il abandonne le MBR obsolète pour cibler directement la partition système EFI (ESP).

Évaluation de la Menace UEFI

La menace réside dans l'exploitation de la vulnérabilité **CVE-2024-7344**. HybridPetya déploie un fichier cloak.dat spécifiquement formaté pour exploiter des applications UEFI vulnérables. Étant donné que les divulgations initiales de 2025 omettaient volontairement les détails d'exploitation, la présence de ce fichier suggère que l'adversaire a procédé par ingénierie inverse pour reconstruire le format propriétaire, témoignant d'une maturité technique exceptionnelle.

Logique d'exécution séquentielle

1. **Phase d'Infiltration (Runtime)**
    - Identification et montage de la partition système EFI (ESP).
    - Déploiement de l'application EFI malveillante et du fichier de configuration cloak.dat.
2. **Phase de Transition (Boot)**
    - Déclenchement d'un redémarrage forcé.
    - Exécution pré-OS :
        - Bypass du mécanisme de **Secure Boot** via l'exploit CVE-2024-7344.
        - Prise de contrôle du flux d'exécution avant le chargement du noyau Windows.
3. **Phase de Chiffrement (MFT)**
    - Exécution de la logique Salsa20 sur les métadonnées de la MFT.
    - Contrairement à NotPetya, l'algorithme de génération de clé permet ici la reconstruction de la clé de déchiffrement, replaçant le malware dans un modèle d'extorsion financière fonctionnel.

---

4. Comparaison Comparative : TTPs et Anti-Forensics

Caractéristique	NotPetya (2017)	HybridPetya (2025)
Cible de démarrage	Master Boot Record (MBR)	UEFI (EFI System Partition)
Provenance Télégramme	Ukraine (Majorité)	Pologne (Source VirusTotal)
Exploit Réseau	EternalBlue (SMBv1)	Non présent (Propagation sélective)
Vol d'identifiants	Extraction LSASS (Mimikatz)	Vecteurs alternatifs probables (Cibles UEFI)
Capacité Secure Boot	Inexistant (Limitation MBR)	**Bypass via CVE-2024-7344**
Motivation Primaire	**Sabotage / Destruction**	**Extorsion Financière**
Récupération Possible	Impossible (Wiper)	Possible (Algorithme réversible)

Techniques Avancées d'Anti-Forensics

L'adversaire applique des mesures agressives pour entraver l'analyse post-mortem :

- **Éviction des journaux :** Utilisation de wevtutil cl pour purger les journaux *Setup*, *System*, *Security*, et *Application*.
- **Destruction du journal USN :** Commande fsutil usn deletejournal pour supprimer les traces de modifications de fichiers.
- **Nettoyage de la mémoire (Wiping) :** Technique critique identifiée consistant à **mettre à zéro les buffers de mémoire** contenant l'exécutable décompressé et les secrets extraits, suivie d'un écrasement des secteurs disque originaux du malware avant toute tentative de suppression de fichier.

---

5. Synthèse pour l'Analyste : Détection et Enjeux Stratégiques

L'évolution vers HybridPetya confirme que la surface d'attaque s'est déplacée vers le micrologiciel. La manipulation de la MFT transforme une infection isolée en une faillite structurelle de l'infrastructure de stockage.

Recommandations de Défense Stratégique

- **Hygiène du Firmware :** Déploiement immédiat des correctifs de microcode UEFI et mise à jour des bases de données DBX pour invalider les certificats compromis associés à la vulnérabilité CVE-2024-7344.
- **Hardening des Privilèges :** Restriction stricte de l'attribution des privilèges SeDebugPrivilege et SeTcbPrivilege aux seuls comptes de service indispensables, limitant ainsi les capacités d'impersonnalisation de jetons.
- **Surveillance de l'ESP :** Implémentation de politiques de contrôle d'intégrité (type EDR avancé) surveillant toute écriture non autorisée sur la partition système EFI, souvent négligée par les analyses de fichiers standards.

---

6. Conclusion : Vers une Cybersécurité de Bas Niveau Incontournable

La trajectoire technique allant de l'extorsion MBR (Petya) au sabotage étatique (NotPetya) pour aboutir à la sophistication chirurgicale UEFI (HybridPetya) démontre une volonté persistante des attaquants de cibler le hardware comme levier de persistence. En contournant le "socle de confiance" via des exploits comme CVE-2024-7344, les adversaires s'assurent une supériorité opérationnelle sur les couches applicatives. La défense des systèmes modernes ne peut plus se limiter à la surveillance de l'OS ; elle doit impérativement intégrer l'intégrité du firmware et la protection des primitives de bas niveau comme première ligne de résistance.